

Эксплуатация уязвимостей

Александр Дорофеев, CISSP, CISA, CISM

Echelon Eyes



@ECHELONEYES

Записи и презентации будут опубликованы в телеграм-канале Echelon Eyes

<https://t.me/EchelonEyes>

Предупреждение

- Рассматриваемые в курсе приемы тестирования защищенности можно отрабатывать только в собственной виртуальной лаборатории в отношении тестовых машин.
- Использование приемов в отношении реальных информационных ресурсов может подпадать под одну из следующих статей УК РФ:
 - УК РФ Статья 272. Неправомерный доступ к компьютерной информации
 - УК РФ Статья 273. Создание, использование и распространение вредоносных компьютерных программ
 - УК РФ Статья 274.1. Неправомерное воздействие на критическую информационную инфраструктуру Российской Федерации
 - УК РФ Статья 274. Нарушение правил эксплуатации средств хранения, обработки или передачи компьютерной информации и информационно-телекоммуникационных сетей



Домашнее задание 3

1. Задать Kali Linux 8 GB RAM.
2. Установить в Kali пакеты docker.io и docker-compose.
3. Обновить базу уязвимостей Сканер-ВС 6.
4. Провести сетевое сканирование портов сервера с Tomcat .
5. Провести поиск уязвимостей.
6. Провести инвентаризацию сервера с Tomcat.
7. Провести поиск уязвимостей.

Игра: Вычисление пароля

PASSWORD

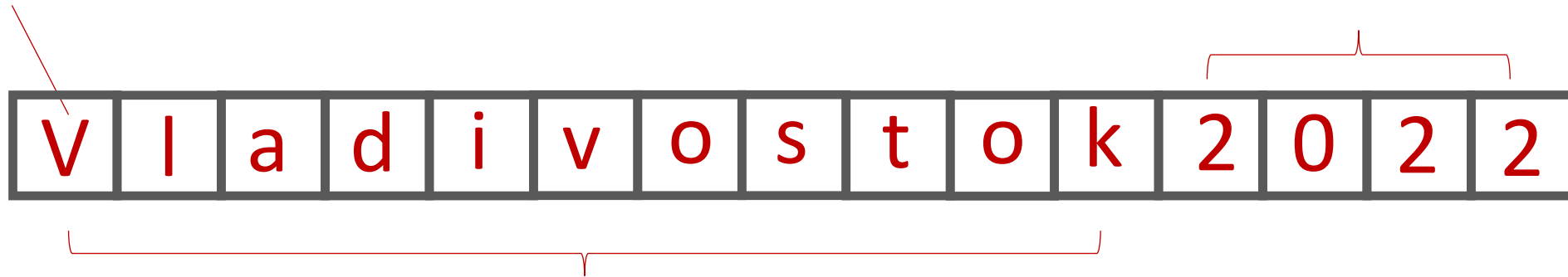
Запишите пароль, удовлетворяющий следующим условиям

1. Легко запомнить
2. Одна буква должна быть в верхнем регистре
3. Как минимум, должна быть одна цифра
4. Длина не менее 8 символов, но не очень длинный, так как его постоянно придется набирать

Поднимите руки, у кого пароль получился примерно таким:

Заглавная буква

Цифры: 1-9, возраст, год, дата.



Дорогое сердцу и поэтому
запоминающееся: человек, домашнее
животное, машина, место, рок-группа,
песня.

**А если бы попросили добавить
спецсимвол?**

\$ @ & ! ?

Остальные трудно запомнить

Какие пароли выбирают пользователи?

- цифры - последовательность или набор одинаковых: 1234, 111111
- номер телефона: 79037777777
- дата рождения: 12121985
- имена (+год рождения): lena, lena85
- клавиатурные последовательности: qwerty,qazwsxedc
- русские слова в английской раскладке: gfhjkm (пароль)

Еще о паролях

- Пользователи любят использовать одинаковые пароли в разных системах
- Есть пароли по умолчанию практически для любой технологии (admin:admin), которые администраторы забывают поменять
- Тестовые аккаунты, как правило, имеют указание «test», а пароль - зачастую пустой пароль или совпадающий с именем учетной записи.
- Системные аккаунты, созданные например, для миграции данных из одной системы в другую, также зачастую имеют слабый пароль.
- Бывают любимые пароли администраторов, назначаемые вновь создаваемым учетным записям: Company1234 и т.п.

Два вида проверок паролей

Offline

```
.MD5Password="08f5b04545cbf7eaa238621b9ab84734"
.MD5Password="09d88c4b9913b791e8f8b3bac2b7236f"
.MD5Password="183983a3ab70bec1f309f5f80a6b2506"
.MD5Password="1f0bfbafab18ab89214db44a0856e24"
.MD5Password="2c0c106032f2663504354179aef97bad"
.MD5Password="2d179ed89a9316cdd1d63391e7a3f013"
.MD5Password="30aa61f920b035ac931caed41673a4a7"
.MD5Password="36dba7f8602b3d79403887dba16e239a"
.MD5Password="3e26ee2841ac919c85a78c28a359c072"
.MD5Password="4ac6e02128ce35eb4e488740cd0582af"
.MD5Password="61214381d7ce51a87493d40d973afd14"
.MD5Password="6b206df5b75124e503045408b6d2b19b"
.MD5Password="794f9c4880cc2220117511b54ab490c"
.MD5Password="8e12503a04fd2dafd9917e3ccdeb2822"
.MD5Password="d681d8224c05f026c41045e05a07bb89"
.MD5Password="e1ee20b165aa536e7b76066003815fbb"
.MD5Password="e39ac1c84fc6f587ae4b4575d879e80a"
.MD5Password="e48d838c248e61b4525bd80408fcf9d1"
.MD5Password="e495b52c8728e195605519af462dba02"
.MD5Password="f62b9dca63a12f5dfdda69a52eafdb1f"
.MD5Password="ffc6ff4600a3081d50c0ceb0cabe2b3"
```

У нас есть база хэшей паролей.

Online

У нас есть доступ к сервису,
запрашивающему логин и пароль .

Hashcat suite

- hashcat – утилита для подбора паролей
- hashcat-utils – вспомогательные утилиты
- maskprocessor (mp64)– генератор словарей по заданным наборам СИМВОЛОВ
- statsprocessor – генератор слов
- princeprocessor – генератор кандидатов в пароли PRINCE algorithm
- kwprocessor – генератор клавиатурных паролей

Варианты атак

- Атака по словарю – проверка всех слов из списка (attack mode 0, - а 0)
- Комбинаторная атака – конкатенация слов из набора списков (mode 1)
- Атака полным перебором – проверка всех символов из заданного набора по каждой позиции (mode 3)
- Гибридная атака – комбинация слово+маска (mode 6) и маска+слово (mode 7); могут приниматься правила
- Ассоциативная атака – использование имени учетной записи, имени файла, подсказки и т.п. для генерации пароля

Алгоритм использования hashcat

1. Определить тип хэша.
2. Подготовить словари, исходя из предположений о том, какие пароли наиболее вероятны.
3. Запустить атаку по словарю на машине с достаточными ресурсами.

Типы хэшей

Generic hash types

Hash-Mode	Hash-Name	Example
0	MD5	8743b52063cd84097a65d1633f5c74f5
10	md5(\$pass.\$salt)	01dfeae5d4d90d9892622325959afbe:7050461
20	md5(\$salt.\$pass)	f0fda58630310a6dd91a7d8f0a4ceda2:4225637426
30	md5(utf16le(\$pass).\$salt)	b31d032cfdcf47a399990a71e43c5d2a:144816
40	md5(\$salt.utf16le(\$pass))	d63d0e21fdc05f618d55ef306c54af82:13288442151473
50	HMAC-MD5 (key = \$pass)	fc741db0a2968c39d9c2a5cc75b05370:1234
60	HMAC-MD5 (key = \$salt)	bfd280436f45fa38eaacac3b00518f29:1234
70	md5(utf16le(\$pass))	2303b15bfa48c74a74758135a0df1201
100	SHA1	b89eaac7e61417341b710b727768294d0e6a277b
110	sha1(\$pass.\$salt)	2fc5a684737ce1bf7b3b239df432416e0dd07357:2014
120	sha1(\$salt.\$pass)	cac35ec206d868b7d7cb0b55f31d9425b075082b:5363620024
130	sha1(utf16le(\$pass).\$salt)	c57f6ac1b71f45a07dbd91a59fa47c23abcd87c2:631225
140	sha1(\$salt.utf16le(\$pass))	5db61e4cd8776c7969cfd62456da639a4c87683a:8763434884872
150	HMAC-SHA1 (key = \$pass)	c898896f3f70f61bc3fb19bef22aa860e5ea717:1234
160	HMAC-SHA1 (key = \$salt)	d89c92b4400b15c39e462a8caa939ab40c3aeaea:1234
170	sha1(utf16le(\$pass))	b9798556b741befdbddcbf640d1dd59d19b1e193
200	MySQL323	7196759210defdc0
300	MySQL4.1/MySQL5	fcf7c1b8749cf99d88e5f34271d636178fb5d130
400	phpass, WordPress (MD5), Joomla (MD5)	\$P\$984478476IagS59wHZvyQMarzfx58u.
400	phpass, phpBB3 (MD5)	\$H\$984478476IagS59wHZvyQMarzfx58u.
500	md5crypt, MD5 (Unix), Cisco-IOS (MD5) ²	\$1\$28772684\$IeWNOgGugqO9.bIz5sk8k/

```

1 hashid '3af0389f093b181ae26452015f4ae728:user'
2 Analyzing '3af0389f093b181ae26452015f4ae728:user'
3 [+] MD5
4 [+] MD4
5 [+] Double MD5
6 [+] LM
7 [+] RIPEMD-128
8 [+] Haval-128
9 [+] Tiger-128
10 [+] Skein-256(128)
11 [+] Skein-512(128)
12 [+] Lotus Notes/Domino 5
13 [+] Skype
14 [+] Domain Cached Credentials

```

https://hashcat.net/wiki/doku.php?id=example_hashes

/etc/shadow

```
mark:$6$.n.:17736:0:99999:7:::
```

```
[--] [----] [---] - [---] ----
```

```
|      |      |      |      |      |||+-----> 9. Unused
|      |      |      |      |      ||+-----> 8. Expiration date
|      |      |      |      |      |+-----> 7. Inactivity period
|      |      |      |      |      +-----> 6. Warning period
|      |      |      |      +-----> 5. Maximum password age
|      |      |      +-----> 4. Minimum password age
|      |      +-----> 3. Last password change
|      +-----> 2. Encrypted Password
+-----> 1. Username
```

Хэш пароля в /etc/shadow

Пароль хранится в следующем формате `$type$salt$hashed` .

`$type` — это алгоритм криптографического хеширования метода и может иметь следующие значения: `$1$` — MD5, `$2a$` — Blowfish, `$2y$` — Eksblowfish, `$5$` — SHA-256, `$6$` — SHA-512

`$salt` — соль

`$hashed` — хэш

Примеры использования hashcat

1) Считаем хэши для паролей из своего готового словаря:

```
hashcat -a 0 -m 500 ./file.hash ./pass.txt
```

2) Формируем словарь по маске и считаем

```
hashcat -a 3 -m 500 ./file.hash ?l?l?ladmin
```

* Built-in charsets:

```
?l = abcdefghijklmnopqrstuvwxyz  
?u = ABCDEFGHIJKLMNOPQRSTUVWXYZ  
?d = 0123456789  
?s = !"#$%&'()*+,-./:;<=>?@[\\]^_`{|}~  
?a = ?l?u?  
?b = 0x00 - 0xff
```

Онлайн-подбор паролей

★

ЗАДАЧИ

Активы

Задачи

Отчеты

Карты сети

Инструменты

Администрирование

[Главная](#) / [Список задач](#) / [Новая задача](#) / Подбор паролей

Подбор паролей

НастройкиРасписание

Настройки задачи

Название

Введите имя задачи...0/100

Цели

10.0.5.1/24,
10.0.5.24,
example.com

Введите цели...+

Импорт из активов

Сервис

ftp

Порт

21

☐ Закончить подбор при первом положительном результате

Пользователи

Словари

Выберите словарь...

Пользователи

Пусто

Введите названия пользователей...+

Пароли

Словари

Выберите словарь...

Пароли

Пусто

Введите пароль...+

☐ Проверить пустой пароль

☐ Проверить пароль, совпадающий с логином

☐ Проверить пароль, совпадающий с логином в обратном порядке

Домашнее задание 4

1. Подобрать пароль к учетным записям СУБД Postgres, проводя онлайн-подбор паролей с помощью Сканер-ВС 6.
2. Подобрать пароль к учетным записям ОС klog и service с помощью hashcat. Информация о паролях: у klog пароль состоит только из чисел, длина пароля не превышает 10 символов, у service – пароль состоит только из букв, является английским словом, длина не превышает 8 символов.

Важный момент

Если экспериментируем с hashcat в отношении уже подобранных паролей, то нужно использовать ключ “--potfile-disable”, чтобы игнорировать предыдущие сохраненные результаты.

Echelon Eyes

Echelon Eyes

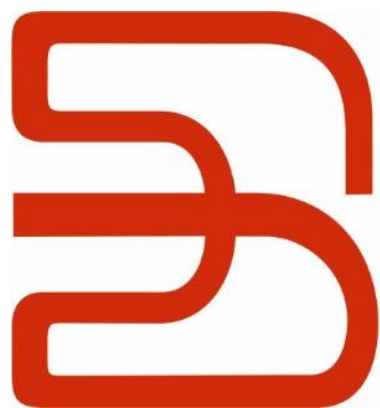


@ECHELONEYES

- Материалы курса: презентации, видео
- Новости об уязвимостях, инцидентах, эксплойтах, изменениях в нормативной базе

**СПАСИБО ЗА
ВНИМАНИЕ!**

Александр Дорофеев
CISSP, CISA, CISM
a.dorofeev@npo-echelon.ru



Эшелон

комплексная безопасность